PROJECT REPORT | 2026

Sentinel AI

AI Code Reviewer & Security Auditor

Find vulnerabilities, fix them, and ship secure code in seconds.

Scan. Secure. Ship.

Google AI Studio | Gemini | OWASP Top 10 | Netlify

PREPARED BY
Hasnain Mehdi

DATE
October 2026

CATEGORY
AI / Developer Security Tool

1 Executive Summary

What Sentinel AI is and why it matters

Sentinel AI is a web-based developer tool that audits source code in seconds. A developer pastes code or uploads a file, picks the language (or lets the app auto-detect it), chooses a review depth, and receives a structured **Security & Quality Audit Report** generated by Google's Gemini models.

The report highlights security vulnerabilities, performance problems and bad coding habits, explains every issue in plain language, and returns a corrected, **production-ready version of the code** that can be copied straight into a project.

3	OWASP	30,000	0
REVIEW MODES	TOP 10 AWARE	CHARACTERS PER AUDIT	CODE STORED ON SERVER

2 Real-World Problem

Why developers need a faster safety net

Code review is slow

After writing code, developers wait for a teammate to review it. This takes hours or even days, and solo developers often have nobody to review their work at all.

Security flaws slip through

Junior and solo developers often write code with hidden loopholes such as **SQL injection, cross-site scripting (XSS) or hardcoded API keys**. Attackers can exploit these to break into a system or steal data.

Performance and quality debt

Inefficient loops, memory leaks and unhandled errors make an app slow and make bugs very hard to find later.

3 Solution and Key Features

One paste, one click, a complete audit

Sentinel AI acts like a senior security engineer on demand. It reads the whole submission at once and returns findings, explanations and fixes in a single structured report.

Security Vulnerability Scanner

Detects security flaws and bugs and highlights them clearly. Looks for OWASP Top 10 risks, injection and XSS issues, dangerous functions, weak cryptography and sensitive data leaks such as hardcoded keys and tokens.

Performance and Code Quality Check

Reviews speed, efficiency and best practices. Points out slow loops, resource leaks, unhandled errors and bad coding habits that make software hard to maintain.

Automated Code Refactoring

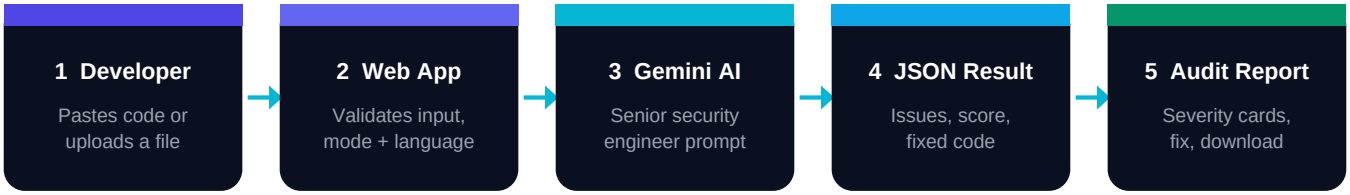
Does not just list mistakes. It generates a fixed, clean, production-ready version of the code that the developer can copy and paste directly.

Built-in conveniences

Paste or upload	Paste code into the editor or upload a source file.
Language selection	Choose a target language or use Auto-detect.
Quick / Standard / Deep	Pick review depth: critical issues only, full OWASP and performance review, or an extended best-practice review.
Sample scenarios	Load ready-made vulnerable examples to try the tool instantly.
Live character counter	Shows input size against the 30,000 character limit.
Responsible-use notice	Reminds users that the audit is AI-assisted and should be verified manually.

4 How It Works

From pasted code to a finished audit report



Typical audit completes in seconds. Code is processed in-session and never stored on disk or server side.

1. **Submit.** The developer pastes code or uploads a file, then selects the language and review mode.
2. **Validate.** The app checks the input (for example, empty input or the 30,000 character limit) before sending it on.
3. **Analyze.** Gemini receives the code together with a system instruction that gives it the role of a Senior Security Engineer.
4. **Structure.** The model answers in a fixed JSON structure, so the interface can always display the results reliably.
5. **Report.** The app renders a score, severity-colored issue cards, the fixed code and recommendations.

5 Technology and AI Design

The stack and the thinking behind the prompts

Layer	Technology	Purpose
AI engine	Google Gemini via Google AI Studio	Analyzes code and generates the fixes. Large context window handles long files in one pass.
Prompting	System instruction: Senior Security Engineer	Gives the model an expert persona so reports are focused, serious and consistent.
Output format	Structured JSON schema	Guarantees a predictable response that the interface turns into cards and tables.
Precision	Low temperature (0.2)	Keeps answers accurate and repeatable instead of creative.
Frontend	Responsive web interface	Code editor, language and mode controls, results dashboard.
Hosting	Netlify	Public live deployment that anyone can open from a link.

6 Audit Report Format

What the developer receives after clicking Run Security Audit

Every audit produces the same clear sections:

- **Overall score and risk level** (Critical, High, Medium, Low or Clean) with a short overview.
- **Severity counts** showing how many Critical, High, Medium, Low and Info issues were found.
- **Issue cards** with title, line numbers, category, why it is dangerous and how to fix it.
- **Fixed code** that is complete and ready to copy into the project.
- **Recommendations** for improving the code further.

Illustrative example of one issue card

CRITICAL **SQL Injection in login query** Line 8 | OWASP A03: Injection

Why it is dangerous: User input is joined directly into the SQL text, so an attacker can enter `' OR '1'='1` and log in without a password or read the whole database.
How to fix: Use parameterized queries so input is always treated as data, never as SQL, and store passwords as salted hashes.

VULNERABLE

```
query = "SELECT * FROM users WHERE
  username = '" + username + "'
  AND password = '" + password + "'"
cursor.execute(query)
```

FIXED

```
cursor.execute(
  "SELECT id, username FROM users
   WHERE username = ? AND password = ?",
  (username, password_hash))
```

This card is a sample to show the report layout. Actual findings depend on the submitted code.

Severity scale used in reports

CRITICAL	Easily exploitable or exposes secrets and data
HIGH	Serious flaw that needs some conditions to exploit
MEDIUM	Real weakness with limited impact
LOW	Minor issue or best-practice improvement

7 Scope, Importance and Responsible Use

Who benefits and what to keep in mind

Who it helps

- **Students** learning secure coding get an instant explanation of every mistake.
- **Solo and junior developers** get a review even when no teammate is available.
- **Companies and teams** can run a quick first-pass check before human code review, saving reviewer time.
- **Portfolios**: the project is a practical, real-world example of applied AI.

Privacy and responsible use

- Submitted code is processed during the session and is **not stored on disk or server side**.
- Users are warned not to paste real production secrets or credentials.
- Every report carries a reminder that the audit is AI-assisted and should be verified by a person.

Limitations

- AI can occasionally **miss a vulnerability or report a false positive**, so Sentinel AI complements, but does not replace, manual review and dedicated static analysis tools.
- Very large projects must be reviewed in parts because of the per-audit character limit.
- Quality of results depends on the code provided and on the Gemini model in use.

8 Future Scope

Where Sentinel AI can grow next

Diff view

Side-by-side comparison of original and fixed code.

Audit history and export

Saved reports and downloadable PDF or Markdown.

Static tool pairing

Combine AI findings with Semgrep or Bandit for higher confidence.

GitHub integration

Automatic review comments on pull requests.

VS Code extension

Audit code without leaving the editor.

Repo-wide scanning and CI/CD

Scan multiple files and block insecure builds automatically.

9 Conclusion

Secure code should not be a luxury

Sentinel AI shows how a large language model can be turned into a focused, practical developer tool. By combining an expert security persona, a low-temperature setting for accuracy and a structured output format, it turns raw code into a clear audit report with ready-to-use fixes in seconds.

The project addresses three real problems at once: slow reviews, hidden security vulnerabilities and poor code quality. It is useful today for students and solo developers, and its roadmap points toward integration with the tools developers already use every day.

Sentinel AI

Scan. Secure. Ship.

Live demo

voluble-centaur-176779.netlify.app

Prepared by

Hasnain Mehdi